



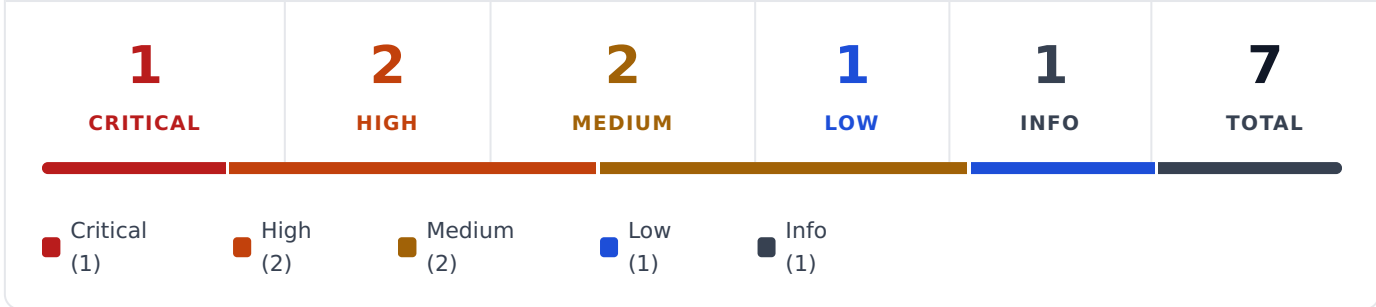
Model Security Assessment Report

9.1

Report ID: HL-20260612-55F88CFC · Generated: June 12, 2026 17:38 UTC · Scanner v2.9.1

CRITICAL

EXECUTIVE SUMMARY



MODEL METADATA

Name	fraud-detection-v3.pkl
Framework	TensorFlow 2.14
Format	SavedModel/h5
File size	299.6 MB
Layers	139
Parameters	142.7M
SHA-256	55f88cfcf010c621b713fb4085f0de d759a62c62ac3305fdda1c4516a3c53 aea

SCAN DETAILS

Scanner	HiddenLayer v2.9.1
Policy set	HL-POL-0012 (Enterprise)
Scan started	2026-06-12 17:38:29 UTC
Scan completed	2026-06-12 17:38:32 UTC
Duration	3.52s
Signatures checked	51,003
Operations analysed	3,966

FINDINGS				7 findings · sorted by severity
ID	SEVERITY	FINDING & REMEDIATION	CATEGORY	LAYER / LOCATION
HL-2024-0041	CRITICAL	Serialized lambda / eval gadget chain Pickle opcode sequence matches known ACE gadget pattern. Deserializing this object on an unpatched runtime executes arbitrary shell commands. Remediation: Re-serialize using safetensors or torch.save with weights_only=True.	Arbitrary Code Execution	__reduce__ / __reduce_ex__
HL-2024-0107	HIGH	Obfuscated tensor payload (base64 stego) High-entropy bytes embedded in unused weight rows. Pattern consistent with steganographic data encoding observed in supply-chain backdoor samples. Remediation: Audit weight provenance; compare checksum against upstream training artifact.	Data Exfiltration / Backdoor	embedding.weight [layer 3]
HL-2024-0203	HIGH	Unsafe custom __getattr__ hook Custom attribute accessor triggers file-system reads outside the model's working directory at inference time. Exploitable in multi-tenant serving environments. Remediation: Remove __getattr__ override; use explicit property accessors.	Privilege Escalation	model.classifi
HL-2024-0318	MEDIUM	Deprecated pickle protocol 2 (policy violation) Model uses pickle protocol 2 (Python 2.3 era). Protocol 5 is required by policy HL-POL-0012 for models deployed in regulated environments. Remediation: Re-export with protocol=5; validate checksum after re-export.	Compliance / Supply Chain	Global header

ID	SEVERITY	FINDING & REMEDIATION	CATEGORY	LAYER / LOCATION
HL-2024-0419	MEDIUM	Unverified third-party operator: torch_xops.fused_matmul Custom C++ extension operator not in HiddenLayer approved operator registry. Origin package (torch_xops 0.3.1) has no published SBOM. Remediation: Pin to a registry-approved operator; open variance ticket if business-critical.	Supply Chain Integrity	layers.4 / layers.11
HL-2024-0512	LOW	Hardcoded internal endpoint in model config Model metadata blob contains a hardcoded URL matching internal MLOps infra pattern (*.internal.corp). Not executable but leaks topology in published artifacts. Remediation: Scrub metadata before publishing; use relative or environment-resolved URIs.	Information Disclosure	model.config / metadata blob
HL-2024-0601	INFO	Missing model card / transparency metadata No model card (README.md / modelcard.json) found. Required by NIST AI RMF MAP-1.5 and EU AI Act Article 13 for high-risk system categories. Remediation: Add a model card documenting training data, intended use, and limitations.	Governance	N/A

This report is generated for authorised security assessment purposes only. Findings are based on static analysis and signature matching; they do not constitute a guarantee of the absence of additional vulnerabilities. Classification: **CONFIDENTIAL** — distribute only to personnel with a need to know.